

THE FORENSICS WAY

ISSUE 26

FORENSICS AWARENESS THIS WEEK

TUESDAY, JULY 28, 2026

FRONT PAGE

AI THREATS

The Malware Wrote Itself: AI-Generated Ransomware Encrypts Your Files From Inside the Browser Tab — No Install Required

Check Point Research this week detailed a milestone that once lived only in security nightmares: a working ransomware technique that DeepSeek generated on demand, combining an unrealistic "browser malware" concept with a very real browser capability — the Chromium File System Access API. The proof, a Python Flask sample dubbed *InfernoGrabber v9.0* uploaded to VirusTotal in January, masquerades as a Discord "AI avatar upscaler" while harvesting Discord tokens, credit-card numbers, and crypto seed phrases, logging keystrokes, and hijacking webcam and microphone. The ransomware variant needs no binary at all: prompted repeatedly, the model produced HTML and JavaScript that walk a victim through a file picker and then encrypt whatever folder they grant — Windows, Linux, macOS, and, because Chrome now exposes the picker on Android, phone camera rolls too.

What makes this a forensic turning point is the disappearance of the artifact investigators are trained to hunt. There is no dropped executable, no install, no persistence key — only a browser tab, a permission grant, and encrypted files. The crime scene moves into the browser sandbox itself. Forensic priority: capture volatile browser and process memory before the tab closes, recover File System Access permission grants and Origin Private File System traces from the Chromium profile, and treat browser history, service-worker caches, and IndexedDB as primary evidence of what the page was allowed to touch.

NATION-STATE

The Operator Was an Algorithm: Suspected Chinese Spies Wired Claude Code and DeepSeek Straight Into a Live Government Intrusion

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-15409

SonicWall SMA 1000 — a server-side request forgery flaw in the Workplace interface lets a remote, unauthenticated attacker force the appliance to make arbitrary internal requests; CVSS 10.0. Exploited as a zero-day since at least June 22 by an actor linked to Inc ransomware, who stole credentials, session data, and even TOTP seeds, then used the box to pivot to internal domain controllers; added to CISA KEV. *Forensic Note:* Review SMA logs for anomalous Workplace requests, rotate all credentials and MFA seeds handled by the appliance, and hunt lateral movement toward domain controllers.

CRITICAL

CVE-2026-63030

WordPress Core — nicknamed "wp2shell," a logic flaw in the REST API batch processor (`/wp-json/batch/v1`) desynchronizes validation and execution, and chained with an SQL injection (CVE-2026-60137) yields unauthenticated remote code execution on a default install; no plugin, account, or user interaction needed. Affects 6.9.0–6.9.4 and 7.0.0–7.0.1; CISA KEV July 21 with public PoCs circulating. *Forensic Note:* Inspect web-server logs for `/wp-json/batch/v1` abuse and `author__not_in` injection, force updates to 6.9.5 / 7.0.2, and hunt newly dropped PHP web shells.

MALWARE SPOTLIGHT

Starland RAT — The Trojan Behind the Fake Installer

Hunt.io researchers uncovered a cyber-espionage campaign that embedded commercial AI directly into the execution flow of live intrusions against government bodies in Afghanistan, Thailand, and Taiwan, with U.S. high-tech supply chains also in scope. The operation ran a split-model architecture: Claude Code served as the agentic execution engine — running bash commands, managing session persistence, and parallelizing tasks — while DeepSeek-v4-pro acted as the reasoning brain, generating exploit scripts and making attack decisions. Investigators surfaced it by pivoting from infrastructure tied to the Go-based TencShell implant, then found an exposed open directory holding victim source code, custom exploit scripts, operational logs, and cloned login pages, with operator notes written in Simplified Chinese.

The timestamps are tight — activity clustered June 8–12 — and the takeaway is stark: a nation-state intrusion where the day-to-day operator work was delegated to a model at machine speed. It is the mirror image of Page 1's AI-written ransomware — one story is AI *writing* the weapon, the other is AI *wielding* it. Forensic priority: preserve the exposed operational logs and AI tool-invocation records as the new intrusion narrative, correlate the June 8–12 timeline against victim access logs, and hunt TencShell alongside the cloned-portal credential harvesting the operators automated.

Tracked by Cisco Talos to the financially motivated actor UAT-11795, Starland RAT rides trojanized copies of legitimate tools — Zoom, WebEx, MobaXterm, DBeaver — delivered by a weaponized HTA that runs via mshta.exe, then an NSIS installer that executes byte-compiled Python. Once resident it inventories hardware IDs, antivirus, and Active Directory data, grabs screenshots, and scans for 40-plus crypto wallets and browser extensions, with a Polygon smart contract as a blockchain fallback for command-and-control. *Forensic Note:* Hunt mshta.exe spawning NSIS installers, review the trojanized app's install path for byte-compiled Python, and watch for outbound calls to Polygon RPC endpoints used to resolve backup C2.

THE FORENSICS WAY

CASE STUDIES: HISTORICAL GRID

WANNACRY (2017)

The Ransomware That Needed No Hacker: How a Self-Spreading Worm Locked 200,000 Machines in a Single Weekend

In May 2017, WannaCry tore across 150 countries in hours, encrypting an estimated 200,000-plus computers — from the UK's National Health Service to Spanish telecoms — by welding ransomware to the leaked EternalBlue SMB

THE MIRAI BOTNET (2016)

An Army of Cameras That Recruited Itself: The IoT Worm That Broke the Internet, Then Open-Sourced Its Own Blueprint

In late 2016, the Mirai botnet marshaled hundreds of thousands of hijacked cameras and routers by automatically scanning the internet for devices still using factory-default passwords, then hurled record-breaking DDoS floods that

exploit so it propagated on its own, with no phishing click and no operator at the keyboard. Investigators reconstructed its spread from network captures and the now-famous kill-switch domain, and Britain's NCSC later attributed it to North Korea's Lazarus Group. WannaCry proved that an automated, self-executing attack could outrun every human responder — the direct ancestor of this week's AI-generated ransomware that assembles and fires itself from inside a browser tab.

knocked out Dyn's DNS and much of the U.S. East Coast's web access. Forensic teams traced the takedowns to the self-propagating worm, and when its author dumped the source code publicly, the automation replicated into countless variants overnight. Mirai showed how attack logic, once automated and released, perpetuates without its creator — the same runaway-automation problem investigators now face as AI models generate and drive attacks on their own.

THE CCLEANER ATTACK (2017)

A Trusted Update, Turned Trojan: When 2.27 Million Users Downloaded Malware Signed by the Vendor Itself

In September 2017, investigators found that attackers had compromised the build environment of Piriform's CCleaner and slipped a backdoor into official, digitally signed releases automatically pushed to roughly 2.27 million users. Forensics revealed a second-stage payload that activated only on a hand-picked list of technology and telecom firms — targeted espionage riding a trusted, automated update channel. Prying malice out of a legitimately signed binary distributed at scale by the vendor's own pipeline prefigures this week's central problem: when the delivery is automated and trusted, from a build server to an AI model, human review never sees the payload before it lands.

THE 3CX CASCADE (2023)

A Supply Chain Inside a Supply Chain: The First Documented Double-Compromise, Traced to a Poisoned Trading App

In March 2023, the 3CX desktop phone app shipped a trojanized build to enterprise customers — but the extraordinary finding came when responders traced the root cause and discovered 3CX had itself been breached through a separate poisoned installer, the X_TRADER app, attributed to North Korea's Lazarus Group. It was the first publicly documented case of one automated supply-chain attack seeding another, forcing investigators to reason about nested, self-propagating chains of trust. That cascading, machine-driven compromise is the historical rhyme for this week's stories, where automated pipelines and AI operators chain one step to the next faster than any analyst can follow.

TOOLS OF THE TRADE

OPEN SOURCE

MemProcFS

ULF FRISK — V5.X

Mounts a memory image — or live RAM — as a browsable filesystem, exposing processes, handles, and network artifacts as ordinary files. Built for exactly this week's browser-native

OPEN SOURCE

hollows_hunter

HASHEREZADE — V0.X

Scans all running processes for in-memory implants — injected code, hollowed modules, and patched regions — and dumps them for analysis. Aimed at fileless threats like AI-generated browser

COMMERCIAL

X-Ways Forensics

X-WAYS SOFTWARE — V21

A lean, deep disk-and-artifact forensics suite favored for carving and timeline work on Windows. Point it at a suspect host to reconstruct the mshta/NSIS installer trail

UTILITY / SCRIPT

FLOSS

MANDIANT — V3.X

Automatically extracts and deobfuscates hidden, stacked, and encoded strings that malware hides from a simple *strings* run. Run it against AI-generated JavaScript droppers or Starland's

ransomware: when there is no disk binary, memory is the crime scene, and MemProcFS lets you walk a Chromium process's memory without scripting a single Volatility plugin.

payloads and Starland's byte-compiled Python: it catches malicious code that lives only in memory, long after the loader that placed it there is gone.

behind Starland, recover Chromium profile artifacts and File System Access grant traces, and rebuild a precise event timeline across registry, prefetch, and browser data.

compiled Python to surface URLs, wallet targets, and Polygon C2 endpoints buried under the obfuscation that both this week's threats lean on.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-58644 (MICROSOFT SHAREPOINT)

A critical remote code execution flaw from deserialization of untrusted data on on-premises SharePoint Server; CVSS 9.8. Advisory July 14, actively exploited; CISA KEV July 16, with IIS machine-key theft observed for persistence. *Forensic Note:* Review SharePoint ULS and IIS logs, rotate IIS machine keys, and hunt web shells dropped for persistence.

ARCHIVE ALERT

CVE-2026-46817 (ORACLE E-BUSINESS SUITE)

An improper-privilege-management flaw in the File Transmission component of Oracle Payments lets an unauthenticated attacker fully compromise Payments via /OA_HTML/ibytransmit; CVSS 9.8. First exploited June 27; CISA KEV July 15. *Forensic Note:* Audit logs for ibytransmit requests, hunt unauthorized Payments transactions, and confirm the patch is applied.

RECENT MALWARE WATCH

ARCHIVE: JULY 21, 2026

CHOCOPOC — THE EXPLOIT YOU CLONED IS THE ATTACK

Disclosed by YesWeHack and Sekoia, ChocoPoC is a Python RAT hidden inside fake proof-of-concept exploit repos, each built around a real flaw in products like FortiWeb, Ivanti Sentry, and PAN-OS. The malice sits in dependencies named *frint* and *skytex*, so a routine pip install lifts passwords, cookies, and files and hands over a shell, using Mapbox as a dead-drop for C2. Review requirements.txt and pip history, and hunt outbound Mapbox API traffic.

ARCHIVE: JULY 14, 2026

MODBEACON — SILVER FOX'S RUST RAT

Attributed by QiAnXin to Silver Fox, a memory-resident, modular Rust RAT that fetches plugins, runs commands, and tunnels command-and-control through gRPC streaming behind Amazon and Cloudflare CDN infrastructure, delivered via SEO poisoning and fake installers. Hunt memory-resident implants with no on-disk payload, inspect outbound gRPC/HTTP2 streams to CDN endpoints, and trace the fake-installer delivery chain.